Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Team Leader:

Name : SWETHA D

College : Navarasam Arts and science college for Women

Email ID : swethadharman25@gmail.com

Team Members:

S.No	Name	College	Email ID
1.	NARMATHA D	Navarasam Arts and science college for Women	td.narmatha@gmail.com
2.	DEVIPRIYA K	Navarasam Arts and science college for Women	devidevipriya91@gmail.com
3.	MADHUBALA K	Navarasam Arts and science college for Women	madhubalakrishnamoorthi26@gmail.com

Project details

Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

This project focuses on integrating **Zscaler** with Identity Providers (IdPs) such as **Microsoft Azure Active Directory**, **Okta**, and **Active Directory** to enable secure and seamless authentication and authorization for users accessing organizational resources.

In many organizations, employees access applications and data from different locations and devices. Traditional network security models often struggle to manage authentication and enforce access policies efficiently. To address this issue, the project implements a cloud-based security architecture where Zscaler acts as a secure gateway between users and applications, while the Identity Providers manage user identities and authentication.

The integration works by connecting Zscaler with the Identity Providers using secure authentication protocols such as **SAML** and **OAuth 2.0**. When a user attempts to access an application or internet resource, Zscaler redirects the authentication request to the configured Identity Provider. The Identity Provider verifies the user's identity and sends an authentication response back to Zscaler. Based on predefined security policies, Zscaler then grants or restricts access to the requested resource.

This integration improves security by enabling centralized identity management, strong authentication, and policy-based access control. It also enhances user experience by supporting Single Sign-On (SSO), allowing users to log in once and access multiple applications without repeated authentication. Additionally, administrators gain better visibility and control over user activity, which helps in monitoring, auditing, and enforcing compliance requirements.

Overall, the project demonstrates how integrating Zscaler with modern Identity Providers can strengthen enterprise security, simplify authentication processes, and provide scalable access management for cloud and on-premises applications.

Abstract:

This project details the integration of the Zscaler Internet security platform with leading Identity Providers (IdPs), including Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to establish a unified identity framework that enables seamless Single Sign-On (SSO) and centralized authorization for all Zscaler services. By consolidating authentication into trusted corporate directories, this initiative eliminates the need for disparate credentials and provides a foundational element for a modern Zero Trust security architecture.

By leveraging industry-standard protocols such as SAML, OIDC, and SCIM, this integration ensures that user authentication is delegated to trusted corporate directories while enforcing consistent security policies, including Multi-Factor Authentication (MFA). This approach not only enhances the user experience by reducing password fatigue but also strengthens the organization's security posture by ensuring that every access request is verified by the identity provider before reaching Zscaler's security enforcement points.

Furthermore, the implementation of automated user provisioning via SCIM streamlines lifecycle management, reducing administrative overhead and enhancing security posture. The outcome is a robust, identity-centric security model that aligns with Zero Trust principles, ensuring that only authenticated and authorized users gain secure access to internet and cloud applications from any location. This integration effectively bridges the gap between identity governance and network security, creating a dynamic and responsive access control environment.

Use Case Scenarios:

Use Case Scenario 1: Remote Faculty Access to Research Data

A research professor is working from an off-campus conference and needs secure access to sensitive research data stored on an internal server. Instead of connecting to the full campus network via VPN, ZPA grants access only to the specific research server. The professor authenticates via the university's identity provider, and access is granted based on their role**.**

Output:

- User identity verified: Research_Faculty_Group
- Context-aware access enforced: Access allowed only from non-campus IP ranges
- Connection restricted: Limited to specific Research File Server (R&D_Server)
- Security enforcement: Multi-Factor Authentication (MFA) required due to off-network location
- No lateral movement: User cannot access other internal systems such as HR or student records

Use Case Scenario 2: Student Access to Library Resources

A graduate student is off-campus and needs access to licensed academic journals and databases hosted internally. Instead of requiring a full VPN tunnel, ZPA provides direct access to the library application portal. The student authenticates via the identity provider, ensuring only enrolled students can access paid subscription content**.**

Output:

- User identity verified: Enrolled_Student_Group
- Access scope defined: Limited to Library Portal and journal databases
- Policy enforcement: Access restricted to authorized users only, preventing credential sharing
- User experience: Seamless SSO without additional VPN client complexity

- No broad network access: Student cannot navigate to administrative systems or internal servers

Use Case Scenario 3: HR Administrator Access to Payroll System

An HR administrator requires access to the payroll system to process monthly salaries. Access must be restricted to specific work hours and require step-up authentication due to the sensitivity of the data. The administrator authenticates via the identity provider, and ZPA enforces timebased and MFA policies.

Output:

- User identity verified: HR_Payroll_Group
- Time-based restriction enforced: Access permitted only during business hours (8:00 AM – 6:00 PM)
- Step-up authentication: MFA triggered upon accessing the payroll application
- Connection restricted: Limited to Payroll Application Server
- Audit trail: Full session logging maintained for compliance purposes

Use Case Scenario 4: IT Helpdesk Remote Troubleshooting

An IT support technician needs to remotely troubleshoot a server issue while working from home. ZPA provides Just-in-Time (JIT) access to the specific server requiring maintenance. The technician authenticates via the identity provider, and administrative privileges are granted only for the duration of the task.

Output:

- User identity verified: IT_Helpdesk_Group
- Just-in-Time access granted: Admin rights elevated only for the active session
- Connection restricted: Limited to the specific target server (Server-X)
- Privilege boundaries enforced: No access to other infrastructure components (databases, domain controllers)
- Session monitoring: Real-time activity logging for security review

Use Case Scenario 5: Contractor Access to Project Management Tool

An external project manager contracted for a specific initiative needs access to the university's project management tool (e.g., Jira or SharePoint). Access must expire automatically upon

contract completion. The contractor authenticates via the identity provider, and ZPA provisions time-limited access based on group membership synchronized from Azure AD.

Output:

- User identity verified: External_Contractor_Group
- Time-bound access policy enforced: Account deprovisioned automatically after contract end date
- Connection restricted: Limited to Project Management Application only
- Segmentation enforced: Contractor cannot discover or access internal resources like finance systems or student databases.

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability Name	CWE - No
1	Improper Sanitization of File Paths	CWE- 284: Improper Access Control
2	Invalid Certificate	CWE-395: Improper Certificate Validation
3	Missing X-Frame-Options Header	CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames
4	X-Content-Type Options Header Missing	CWE -918: Server Side Request Forgery (SSRF)
5	Drupal Ajax API shows JSONP not disabled by default	CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with

		Known Vulnerabilities
6	Drupal Api Vulnerability	CWE-20: Improper Input Validation
7	Improper API Filtration	CWE-79: Improper Neutralisation of Input During Web Page Generation ('Cross-site Scripting')
8	Denial of Service	CWE -400: Uncontrolled Resource Consumption
9	TLS Version 1.0 Protocol Detection	CWE-327: Use of a Broken or Risky Cryptographic Algorithm
10	web.config File Information Disclosure	CWE-497: Exposure of Sensitive System Information to an Unauthorised Control Sphere

Main Website:

S.no	Vulnerability Name	CWE - No
1	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation

3	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1)Vulnerability Name: Improper Sanitization of File Paths

CWE: CWE-284 – Improper Access Control
OWASP Category: A01:2021 – Broken Access Control

Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Recommendation

1. **Apply Security Updates:** Install the latest Drupal security patches to fix known vulnerabilities.
2. **Review Configuration:** Verify file permissions and ensure private files are properly protected.
3. **Regular Audits:** Perform periodic security audits and vulnerability assessments.
4. **Access Control:** Restrict access so only authorized users can view sensitive files.
5. **Data Minimization:** Store only necessary sensitive data on the website.

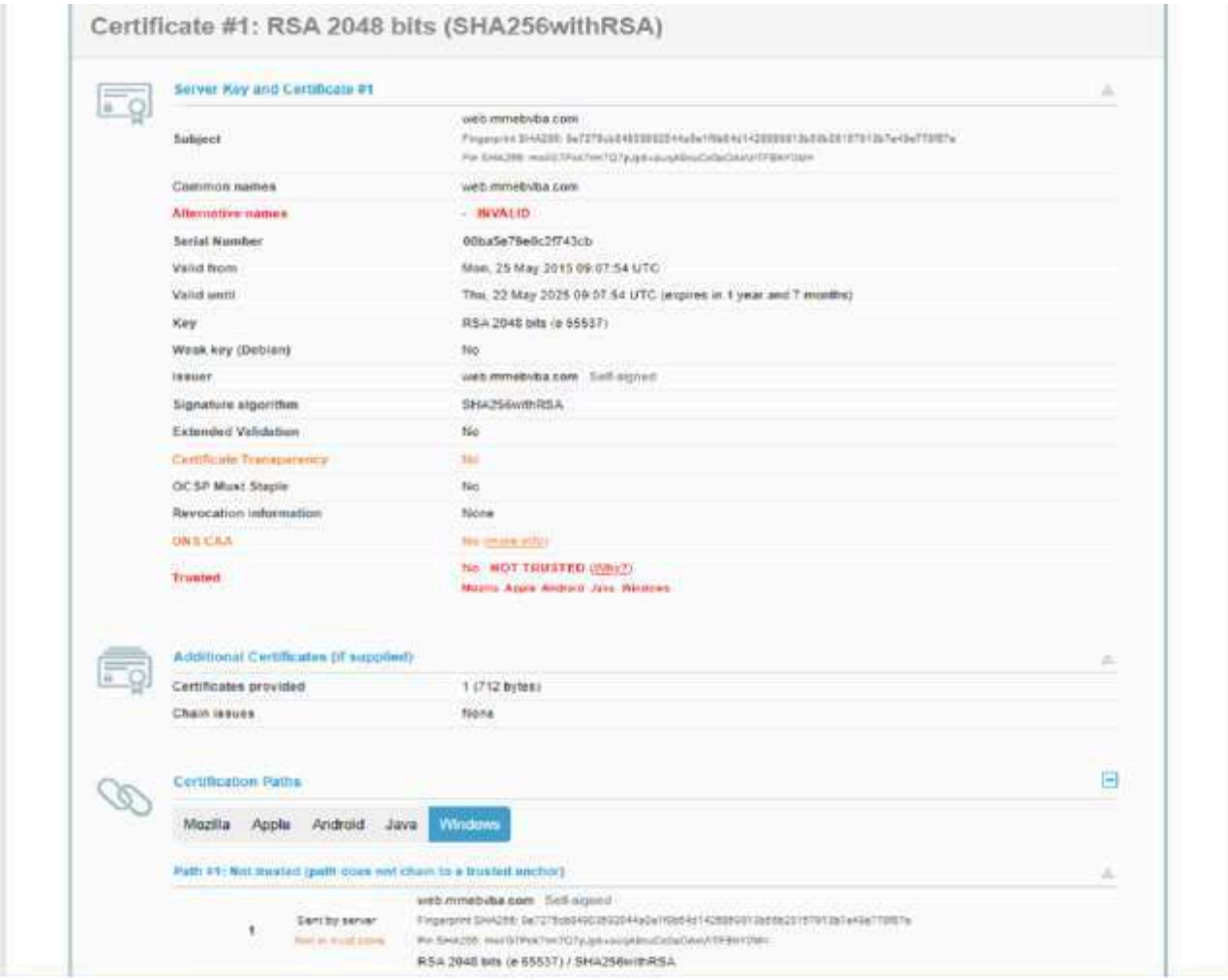
2)Vulnerability Name: Invalid Certificate

CWE-395 – Improper Certificate Validation
OWASP Category: A07:2021 – Identification and Authentication Failures

Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact: Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Steps to Reproduce:https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com



Recommendation

1. **Use Trusted Certificate Authorities:** Trust certificates only from recognized certificate authorities. 2. **Verify Certificate Chains:** Ensure the certificate and its chain are valid and issued by a trusted CA.
3. **Check Revocation Status:** Confirm the certificate has not been revoked**.**
4. **Implement Certificate Pinning**: Restrict communication to specific trusted certificates**.**
5. **Keep Software Updated:** Regularly update software and security protocols to fix vulnerabilities.

3) **Vulnerability Name:** **Missing X-Frame-Options Header**

CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames

OWASP Category: A04:2021-Insecure Design

Description: A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the

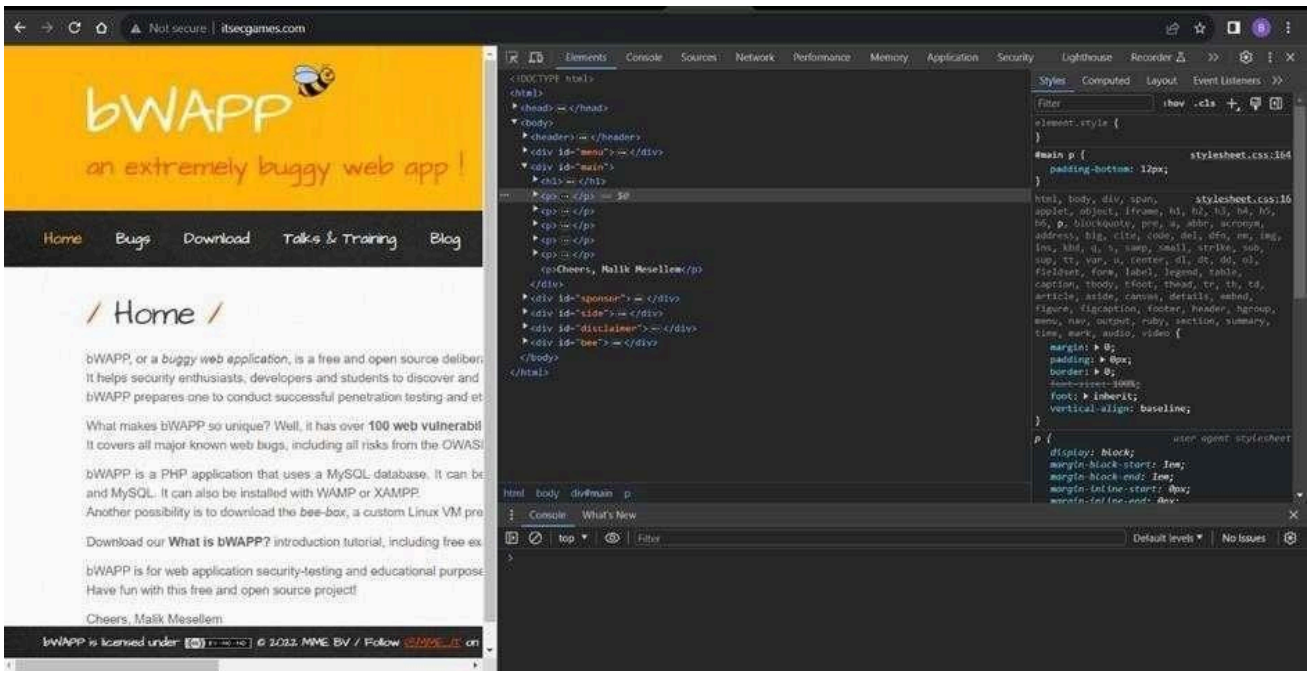
restrictions, users can be tricked into interacting with the application when they were not intending to.

Business Impact: This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses.

Vulnerability Path: http://www.itsecgames.com/

Steps to Reproduce:

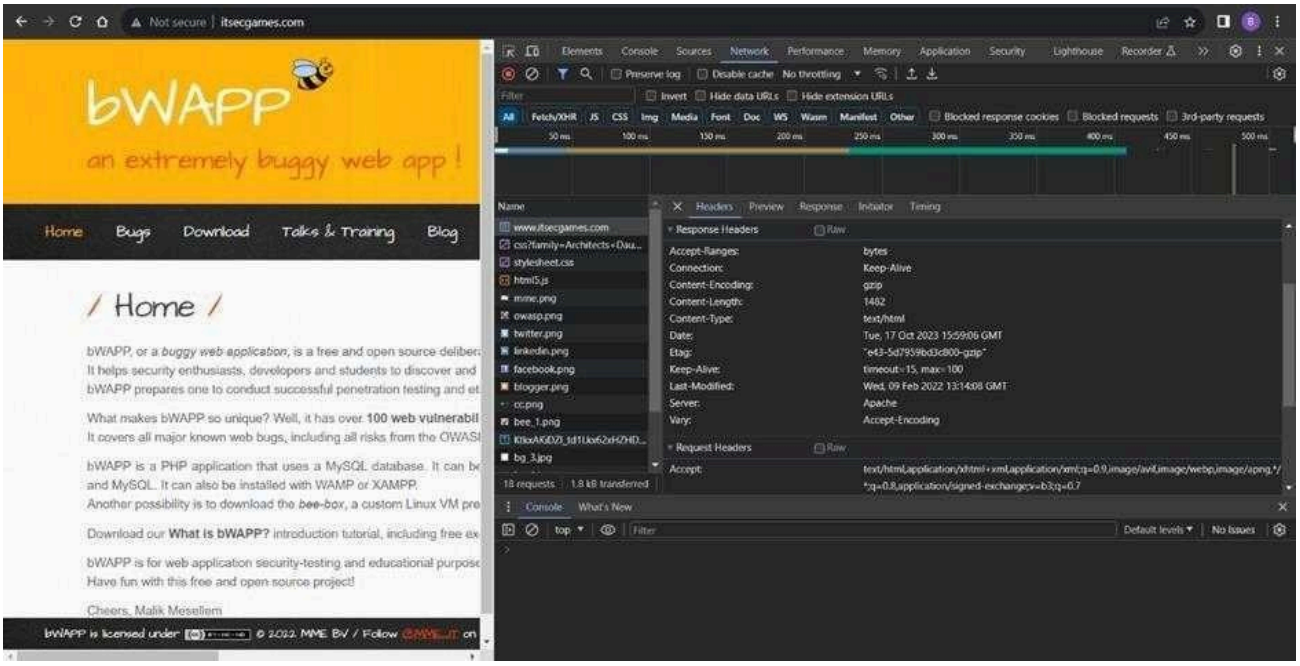
1. Open the practice website to inspect



2. Go to network and start capturing using F5 or Ctrl+R

3. Go to html document and see if x-frame-options present in response headers or not

4. If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.



Recommendation:

1. **Implement UI Access Controls:** Restrict access to UI layers based on user privileges.
2. **Strong Authentication & Session Management:** Use secure authentication and proper session handling to prevent unauthorized access.
3. **Use Content Security Policy (CSP):** Configure CSP headers to control resource loading and prevent frame-based attacks.
4. **Update Software Regularly:** Keep applications and libraries updated to fix known vulnerabilities.

4) Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

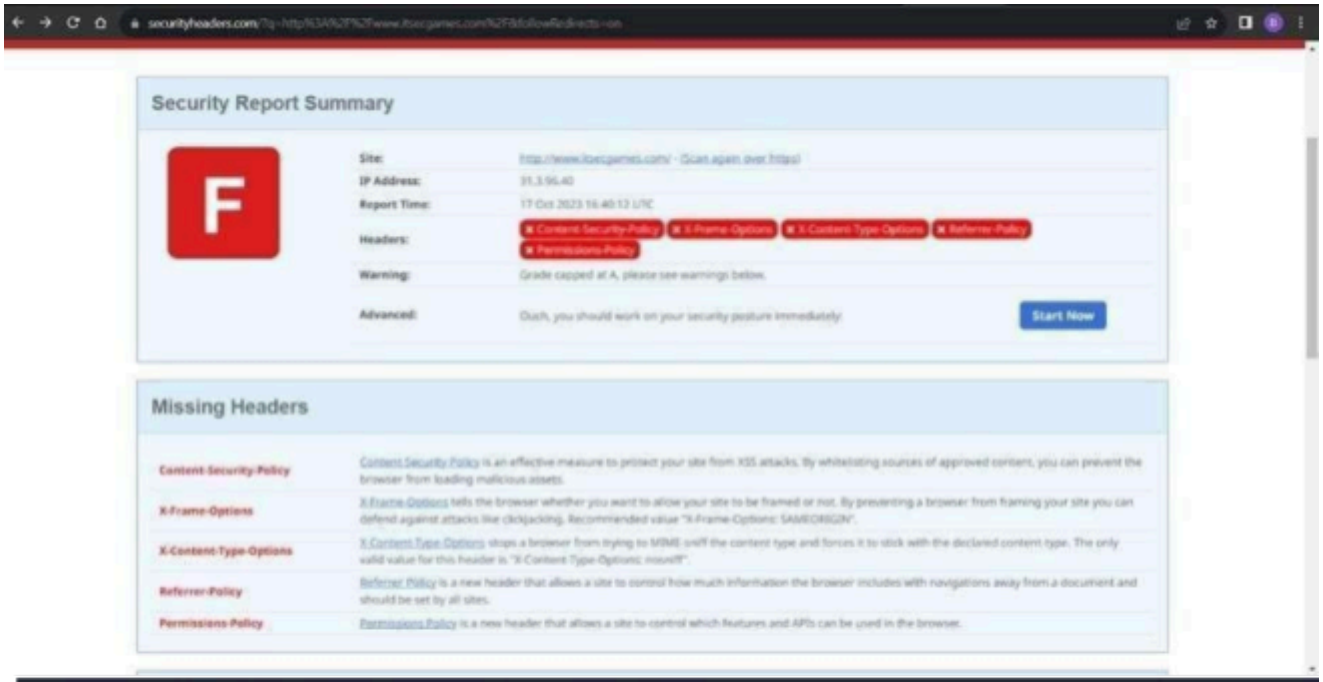
Description: The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :

https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects=on

Steps to Reproduce:




```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    www.itsecgames.com
+ Target Port:        80
+ Start Time:         2023-10-17 09:03:40 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-
vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/proje
ct/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31
.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800,
 mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2023-10-17 09:29:14 (GMT5.5) (1534 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation

- **Implement X-Content-Type-Options Header:** Configure the X-Content-Type-Options: nosniff header to prevent content type sniffing.
- **Mitigate SSRF:** Use strong input validation, access controls, and allow-list URL validation to block unauthorized internal requests**.**
- **Use Security Headers:** Apply headers such as X-Frame-Options and Content-Security-Policy to reduce web-based attacks.

5) Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components

Description: Vulnerable and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities.

Business Impact: The presence of vulnerable and outdated components in a web application poses significant security risks. Attackers can exploit these weaknesses to gain unauthorized access, inject malicious code, steal sensitive data, or disrupt the system's operation. The potential business impacts include compromised user data, damaged reputation, legal consequences, and financial losses due to breach recovery and remediation efforts.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13666	**4.3** Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Recommendation

1. **Regular Updates:** Keep software components, libraries, and dependencies updated with security patches.
2. **Vulnerability Scanning:** Perform regular vulnerability assessments to detect security issues.
3. **Dependency Management**: Monitor and manage third-party dependencies for security risks.
4. **Security Testing**: Conduct periodic penetration testing and code reviews.
5. **Change Control**: Use a change management process to prevent new vulnerabilities during updates.

6) Vulnerability Name: Drupal Api Vulnerability

CWE-20: Improper Input Validation

OWASP Category: A03:2021 – Injection

Description: The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Business Impact: The impact of a successful SQL injection attack can be devastating for businesses. It can result in unauthorized access to sensitive information, data theft, financial losses, damage to reputation, and legal consequences. Depending on the nature of the application and data involved, SQL injection can lead to compliance violations, customer trust erosion, and operational disruption.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2022-25271	4.3 Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Recommendation

1. **Input Validation:** Validate and sanitize all user inputs before processing.
2. **Parameterized Queries:** Use prepared statements to prevent SQL injection.
3. **Escape User Input:** Escape special characters if parameterized queries are not possible.
4. **Least Privilege:** Limit database permissions to the minimum required.
5. **Use WAF:** Deploy a Web Application Firewall to block malicious requests.
6. **Regular Security Testing:** Perform periodic security assessments and penetration testing.

7) Vulnerability Name: Improper API Filtration

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-site Scripting (XSS)

Description: The product does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users.

Business Impact: If exploited, this vulnerability allows attackers to inject malicious scripts into web pages, which can be viewed by other users. The potential business impacts

include data theft, unauthorized access, compromised user accounts, damaged reputation, and financial losses. Attackers can use XSS to steal sensitive information, such as user credentials, personal data, or financial details, leading to regulatory compliance violations and legal liabilities. Additionally, defacement or manipulation of website content can erode customer trust and result in lost revenue.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13672	**2.6** Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

8) Vulnerability Name: **Denial of Service**

CWE -400: Uncontrolled Resource Consumption

OWASP Category:

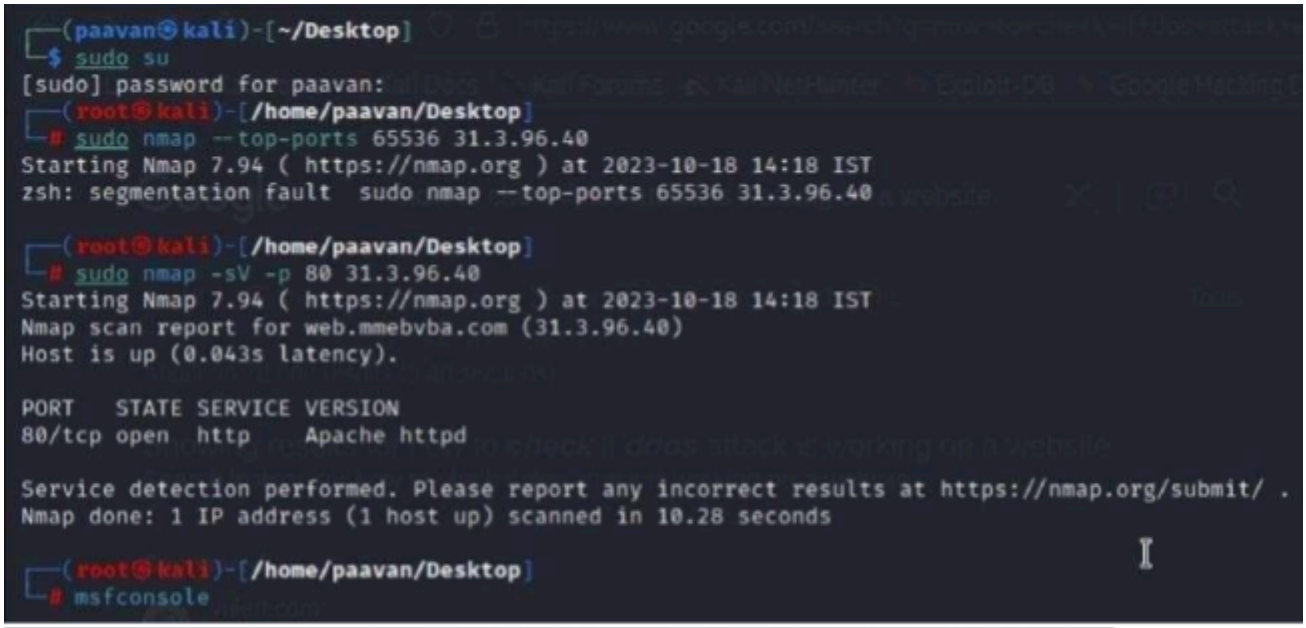
Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.

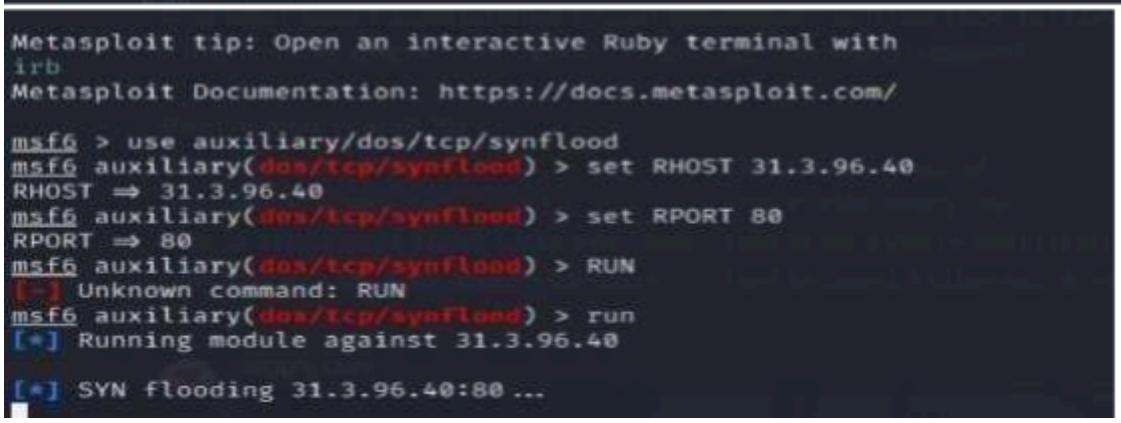
Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server.
Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and

confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.





Recommendation

- **Use Web Application Firewall (WAF):** Deploy a WAF to filter malicious traffic targeting port 80.
- **Load Balancing:** Distribute traffic across multiple servers to prevent overload.
- **Rate Limiting:** Restrict the number of requests from a single IP address.
- **Traffic Monitoring:** Monitor traffic patterns and set alerts for unusual activity.
- **Regular Updates:** Keep systems and software updated with the latest security patches.

.

9) Vulnerability Name: **TLS Version 1.0 Protocol Detection**

CWE-327: Use of a Broken or Risky Cryptographic Algorithm

OWASP Category: A02:2021-Cryptographic Failures

Description: The product uses a broken or risky cryptographic algorithm or protocol.

Business Impact: TLS 1.0 is an outdated and vulnerable encryption protocol, and its use can expose sensitive data to potential security threats. This not only jeopardizes the integrity of customer information and payment details but also tarnishes the company's reputation. The business may face legal consequences, loss of customer trust, and decreased revenue as security-conscious users avoid the site due to its security vulnerabilities. Immediate action is necessary to upgrade to a more secure TLS version to safeguard data, ensure compliance, and maintain customer confidence.

Steps to Reproduce:

1. Open a terminal or command prompt

2. Type the Command: openssl s_client -connect 31.3.96.40:443 -tls1

3. The connection is successfully means the server supports TLS 1.0

```
No ALPN negotiated
SSL-Session:
    Protocol  : TLSv1
    Cipher    : ECDHE-RSA-AES256-SHA
    Session-ID: 88C081DC5A60B2165E5ECF1174DFFA77732428624861E0BFAC934E3DE969B9E2
    Session-ID-ctx:
    Master-Key: 9A895BD34544E92181A631AB636C46EEC2788E9BFEE0DA5A6BDCA50E65C55250BA88EA
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
    0000 - 11 e0 e2 5c 44 79 52 91-7b 32 b1 10 22 9f 80 b5   ...\DyR.{2..".....
    0010 - 54 b6 b7 89 fe c7 7d 4a-18 bd 8c e3 e6 31 47 63   T.....}J.....1Gc
    0020 - 38 1b 52 ec 16 ac 18 b6-bd e1 76 e9 4b 41 24 ad   8.R.......v.KA$.
    0030 - e3 94 d2 60 65 35 8b e0-6e d2 76 db 1b e1 03 e7   ...`e5..n.v.....
    0040 - e7 76 cc f9 70 6a 42 91-94 42 e2 e8 29 d5 fd 38   .v..pjB..B..)..8
    0050 - 63 5f da 9f 09 af e0 d9-22 29 45 70 a7 a4 36 1f   c_......")Ep..6.
    0060 - 51 b1 cd d5 e7 b9 ef 9d-5d 20 99 ad 00 4d 21 df   Q.......]  ...M!.
    0070 - 38 a6 c9 1b 76 29 87 d9-14 79 7a 73 33 f8 4c 8f   8...v)...yzs3.L.
    0080 - 12 ae 66 c1 ad c3 6c ba-68 63 11 6c b2 18 e0 89   ..f...l.hc.l....
    0090 - 97 54 50 d7 ee f5 e1 37-f4 b0 be 55 2f d1 25 63   .TP....7...U/.%c
    00a0 - c7 61 10 b3 ad 74 5a b7-07 fe e5 20 b1 da a1 a2   .a...tZ.... ....
    00b0 - be dd c8 45 a7 74 b7 eb-ee 9a 15 dc 1b bb 0b d9   ...E.t..........

    Start Time: 1697691531
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: no
---
4037A3514B7F0000:error:0A000126:SSL routines:ssl3_read_n:unexpected eof while reading:
```

Recommendation

1. **Upgrade TLS Version**: Use secure protocols like TLS 1.2 or TLS 1.3.
2. **Update SSL/TLS Configuration**: Regularly update configurations to follow current security best practices.
3. **Use Strong Cipher Suites**: Disable weak ciphers and outdated protocols.
4. **Ensure Compliance**: Follow security standards such as GDPR and PCI DSS.

10) Vulnerability Name: web.config File Information Disclosure

CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere

OWASP Category: A3:2017-Sensitive Data Exposure

Description: An information disclosure vulnerability exists in the remote web server due to the disclosure of the web.config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.

Business Impact: It exposes sensitive configuration details, including database connection strings and encryption keys, to potential attackers. This could lead to unauthorized access, data breaches, and system compromise. The impact includes financial losses, damage to reputation, and legal liabilities as the organization's security and customer trust are compromised.

Steps to Reproduce:

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation

- **Restrict Access:** Implement proper access controls to protect the web.config file.
- **Prevent Direct Access:** Block directory traversal and direct web access to the configuration file.
- **Encrypt Sensitive Data:** Store sensitive information in encrypted form.
- **Regular Reviews:** Periodically review and remove unnecessary sensitive data.
- **Secure Configuration:** Ensure the configuration file is accessible only to authorized users.

Main Website: vtop.vit.ac.in

1) Vulnerability Name: SL Medium Strength Cipher Suites Supported (SWEET32)

CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

OWASP Category: Broken access control

Description: The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Business Impact: The vulnerability known as SWEET32 (Short for Sweet 32 Birthday Attack) relates to the continued use of legacy cryptographic cipher suites with 64-bit block sizes in TLS and SSL protocols. These suites are susceptible to birthday attacks, which exploit the probability of two blocks colliding after a certain number of transactions. If an organisation's systems are vulnerable to SWEET32, it means they're potentially at risk of having encrypted communications intercepted or manipulated. This could lead to unauthorised access, data theft, or even the injection of malicious code. As a result, businesses face a significant risk to the confidentiality and integrity of their sensitive information. Remediation involves updating systems to support more secure cipher suites with larger block sizes, which would effectively mitigate this vulnerability and enhance the overall security posture. Failure to address SWEET32 could leave an organisation exposed to increasingly sophisticated attacks and legal consequences due to potential data breaches.

Vulnerability Path : The Sweet32 vulnerability when detected with a vulnerability scanner will report it as a CVSS 7.5.

Steps to Reproduce:

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                    Code        KEX     Auth    Encryption          MAC
  ----------------------  ----------  ---     ----    ------------------  ---
  EDH-RSA-DES-CBC3-SHA    0x00, 0x16  DH      RSA     3DES-CBC(168)       SHA1
  ECDHE-RSA-DES-CBC3-SHA  0xC0, 0x12  ECDH    RSA     3DES-CBC(168)       SHA1
  DES-CBC3-SHA            0x00, 0x0A  RSA     RSA     3DES-CBC(168)       SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	136.233.9.22

Plugin Details

Severity:	High
ID:	42873
Version:	1.21
Type:	remote
Family:	General
Published:	November 23, 2009
Modified:	February 3, 2021

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Risk Factor: Medium
CVSS v3.0 Base Score 7.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 24, 2016

Recommendation

- **Disable Weak Cipher Suites:** Remove TLS/SSL cipher suites with 64-bit block sizes to prevent **SWEET32 attack**.
- **Use Secure TLS Configurations:** Enable only modern encryption protocols and strong cipher suites.
- **Regular Updates:** Apply security patches and monitor systems for outdated protocols.
- **Forward Secrecy:** Use strong encryption keys and enable forward secrecy for better protection.
- **Security Monitoring:** Deploy intrusion detection systems and perform regular security audits to detect vulnerabilities early.

2) Vulnerability Name: Cookie SERVERID created without secue flag

CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A07-2017: Cross-site Scripting

Description: The vulnerability allows an attacker to inject malicious code into a WordPress website, which can then be executed by visitors to the website.

To exploit this vulnerability, an attacker would simply need to trick a user into clicking on a malicious link or opening a malicious attachment. Once the user clicks on the link or opens the attachment, the attacker's code would be executed, giving the attacker control over the user's account and potentially the entire WordPress website.

Business Impact: The business consequences of XSS can be severe, ranging from reputational damage due to compromised customer trust, to legal repercussions in cases of data breaches. Moreover, it can lead to financial losses through fraud or the cost of remediation efforts. Beyond the immediate impacts, long-term harm may occur if customers abandon the platform due to security concerns. To mitigate CWE-79, businesses must implement rigorous input validation and output encoding practices, as well as stay vigilant for emerging threats in web application security. Failure to address XSS vulnerabilities could result in significant harm to both the business's reputation and its bottom line.

Vulnerability Path: https://securityheaders.com/

q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation

1. **Update and Patch:** Keep Drupal and its modules updated with the latest security patches.
2. **Input Validation:** Sanitize and validate all user inputs to prevent malicious scripts.

3. **Content Security Policy:** Implement CSP headers to restrict content sources and reduce CrossSite Scripting risks.
4. **Secure Coding:** Follow secure coding practices and properly escape user inputs.
5. **Security Scanning**: Perform regular vulnerability scans and penetration testing**.**

3) **Vulnerability Name: X-Content-Type Options Header Missing**

CWE-918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The absence of the "X-Content-Type-Options" header poses a notable security risk for web applications. This header is a crucial security feature that instructs the browser to interpret files with a MIME type as declared in the Content-Type header, rather than trying to guess the type. When this header is missing, the browser may attempt to infer the content type, leaving room for potential misinterpretation and security vulnerabilities like MIME-sniffing attacks. This could enable attackers to disguise malicious content, such as scripts or executable files, as benign content, leading to Cross-Site Scripting (XSS) or other types of attacks. Implementing the "X-Content-Type-Options" header with the value "nosniff" is a fundamental security measure that helps prevent these risks. It ensures that browsers strictly adhere to the declared content type, enhancing the overall security posture of the web application and safeguarding against potential exploitation stemming from content misinterpretation.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :
https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation

- **X-Content-Type-Options Header:** Configure X-Content-Type-Options: nosniff to prevent content type sniffing.
- **Mitigate SSRF:** Apply strong input validation, access controls, and allow-list URL validation to prevent **Server-Side Request Forgery** attacks.
- **Security Headers:** Implement headers such as X-Frame-Options and Content-Security-Policy to improve overall web security.

4) **Vulnerability Name: Denial of Service**

CWE - 400: Uncontrolled Resource Consumption

Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.

Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server.

Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 443 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 18:27 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.044s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1 c
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Linux 5.1 (87%), Apple macOS 10.13 (High Sierra
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

Recommendation

- **Web Application Firewall:** Deploy a WAF to filter malicious traffic targeting port 80.
- **Load Balancing:** Distribute traffic across multiple servers to prevent overload.
- **Rate Limiting:** Limit requests from a single IP to reduce attack impact.
- **Traffic Monitoring:** Monitor network activity and configure alerts for unusual spikes.
- **Regular Updates:** Keep systems patched to prevent exploitation of known vulnerabilities.

5) **Vulnerability Name:** **OS Identification**

CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

OWASP Category: A02:2021-Cryptographic Failures

Description: Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact: If sensitive information is improperly handled or inadequately protected, it can lead to financial losses, regulatory penalties, and damage to reputation. Customers may lose trust in the organization's ability to safeguard their data, potentially resulting in a loss of business and market share. Legal consequences and compliance issues may arise, leading to additional costs. Moreover, intellectual property theft or exposure can compromise a company's competitive edge. Remediation efforts, including implementing stronger security measures and compensating affected parties, can also entail substantial expenses. Overall, CWE-200 highlights the critical importance of robust data protection measures to safeguard an organization's financial health, reputation, and long-term viability.

Steps to Reproduce: use nmap -O TARGET to enable os detection

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 19:13 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.043s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:apple:mac_os_x:10.13 cpe:/o:linux:linux_kernel:5.1
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Apple macOS 10.13 (High Sierra) (Darwin 17.0.0) (86%), Linux 5.1 (86%), Linux 3.2 - 4.9 (86%), Linux 3.18 (
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
```

Recommendation

- **Strong Encryption:** Protect sensitive data using encryption for data in transit and at rest.
- **Access Control & Authentication:** Implement strict access controls and strong authentication mechanisms.
- **Regular Security Testing:** Conduct vulnerability assessments and penetration testing to identify weaknesses.
- **Security Awareness Training:** Educate employees on secure data handling and threat recognition.
- **Data Protection Measures:** Use data masking and **Data Loss Prevention** solutions to prevent sensitive data exposure.
- **Compliance & Incident Response:** Follow data protection regulations and maintain a clear incident response plan.

This is stage 1 in the context of web application testing and security we take help from

OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most critical web application security risks. Understanding these risks is essential for ensuring the security of web applications.

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices. ● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446

7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) **Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection**

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non- compliance risks regulatory penalties and erodes customer trust. Moreover,

endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1 As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections. **Solution: -** Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as

part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host.

Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure.

Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) Vulnerability Name: - 39446 - Apache Tomcat Detection Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or

impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590 **Port: -** 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE

(Common Platform Enumeration) matches for various hardware and software products found on

a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8) Vulnerability Name: - Device Type Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network management, optimization, and ensures that the right security measures are in place for each device type.

9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL- stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS**.**

Business Impact: -Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

10) Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

Stage-3

Title: - Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Legacy Authentication Challenges

Traditional VPN architectures follow an **"authenticate once, trust indefinitely"** model that grants networklevel access after login. This approach creates several security and operational problems. Users often receive excessive permissions, allowing lateral movement across systems. VPN gateways must be exposed to the internet, making them targets for brute-force attacks, scanning, and vulnerability exploitation.

Remote traffic is commonly routed through data centers before reaching the internet, causing latency and poor user experience. Hardware VPN appliances also have capacity limits, requiring manual upgrades during peak usage. IT teams must constantly maintain, patch, and monitor these appliances.

Another major issue is **identity fragmentation**. Legacy models usually lack integration with modern identity providers, forcing administrators to maintain duplicate user accounts across multiple systems. These

limitations highlight the need for a modern **identity-centric security model** where authentication is handled by enterprise IdPs and access is based on identity rather than network location.

Zero Trust Identity Principles

Zscaler-IdP integration is built on **Zero Trust Architecture**, which assumes no implicit trust in users or networks. Every access request must be verified regardless of location.

Key principles include:

- **Never Trust, Always Verify** – every session requires authentication and authorization.
- **Least Privilege Access** – users receive only the minimum permissions needed for their role.
- **Assume Breach** – systems are designed with the expectation that attackers may already be present.
- **Micro-Segmentation** – users connect only to specific applications rather than the entire network. In this model, **identity becomes the new security perimeter**. Access decisions consider user identity, device posture, location, and behavior in real time rather than relying on static network rules.

Supported Identity Providers and Protocols

Zscaler integrates with several enterprise identity providers using standard authentication protocols.

Common integrations include:

- **Microsoft Entra ID (Azure AD)** using **SAML 2.0** for authentication and **SCIM** for user provisioning.
- **Okta** using **OpenID Connect (OIDC)** and **SCIM** for automated lifecycle management.
- **Active Directory** through the **Zscaler Authentication Bridge (ZAB)**, which securely connects Zscaler cloud services with on-premises domain controllers.

Additional supported providers include **Ping Identity**, **OneLogin**, and other SAML-compatible systems. Supported protocols include:

- **SAML 2.0** – browser-based single sign-on
- **OIDC** – modern application authentication
- **LDAP** – on-premises directory integration
- **SCIM** – automated user provisioning

This multi-protocol support allows organizations to integrate existing identity infrastructure without major redesign.

Prerequisites and Licensing

Before integration, several technical and administrative requirements must be met.

Organizations need active subscriptions to **Zscaler Internet Access (ZIA)** or **Zscaler Private Access (ZPA)** with SSO and SCIM provisioning enabled. Administrators must have sufficient privileges in both the Zscaler Admin Portal and the chosen identity provider.

Network requirements include allowing outbound HTTPS traffic (TCP 443) from connectors and endpoints to Zscaler cloud services. For on-premises directory integration, Windows servers must host the **Zscaler Authentication Bridge** with connectivity to domain controllers.

Proper DNS configuration, SSL certificates for SAML signing, and planning of user attributes such as email, UPN, and group memberships are also required for successful deployment.

Discovery and Requirements Gathering

The discovery phase documents the existing identity and application environment.

Organizations should identify all internal applications accessed through legacy VPN systems, including ERP systems, research servers, file shares, and administrative portals. For each application, record protocols, ports, IP addresses, and user groups that require access.

User segmentation is also essential. Typical categories include faculty, students, IT administrators, staff, and external collaborators. Existing authentication methods, MFA requirements, and identity sources should be documented.

This process ensures that all systems and access requirements are understood before implementing Zscalerbased authentication.

Identity Source Architecture Planning

Organizations with hybrid environments must determine which directory acts as the **primary identity source**.
For example, authentication may occur through **Microsoft Entra ID with synchronization from on-premises **Active Directory**. Alternatively, direct LDAP authentication through the **Zscaler Authentication Bridge** may be used.

Attribute mapping between directories and Zscaler must be planned carefully. Critical attributes include userPrincipalName, email, name fields, and group memberships. Directory synchronization frequency, group management strategies, and disaster recovery scenarios should also be defined.

Phased migration is recommended, starting with pilot user groups before expanding to full production deployment.

Application Discovery and Categorization

All internal applications requiring secure access must be identified and classified before configuring policies. Network logs, firewall records, and discovery tools can help identify applications used by remote users. For each application, record the domain name or IP address, protocol, port, and application type such as web services, remote desktop, or databases.

Applications should be categorized by sensitivity level:

- Public information
- Internal use
- Confidential
- Restricted

Dependencies between applications should also be documented to avoid disrupting functionality when implementing segmentation policies.

User Group and Attribute Planning

Granular access control requires clear group structures within the identity provider.

Organizations should define groups based on functional roles such as faculty, researchers, students, administrative staff, IT personnel, and contractors. Group nesting strategies can simplify policy management, allowing parent groups to contain multiple department-level subgroups.

Key user attributes may include department, role, location, and employment type. These attributes enable dynamic policy assignment within Zscaler.

A **group-to-application mapping matrix** should also be created to clearly define which users are allowed to access each application.

Infrastructure Readiness Assessment

Before deployment, infrastructure must be evaluated to ensure compatibility with Zscaler services. Network performance between users and Zscaler data centers should be tested to identify potential latency issues. Firewalls must allow outbound connections to Zscaler domains, and SSL inspection policies should not interfere with authentication traffic.

Organizations must also ensure sufficient resources for deploying Zscaler App Connectors, including CPU, memory, and storage. High availability designs should include multiple connectors across different failure domains.

Endpoint readiness should also be verified by confirming that user devices support the **Zscaler Client Connector**.

Azure AD Integration (SAML and SCIM)

Integration with **Microsoft Entra ID** is typically performed using **SAML for authentication** and **SCIM for provisioning**.

Administrators create a Zscaler enterprise application within Azure AD, configure SAML settings with the Zscaler Identifier and Reply URL, and map user attributes such as UPN, email, and group memberships. SCIM provisioning is then enabled to automate user lifecycle management. This allows Azure AD to create, update, and deactivate users automatically in Zscaler.

Okta Integration (OIDC and SCIM)

Organizations using **Okta** typically configure authentication using **OpenID Connect**.

Administrators create an OIDC application in Okta, configure redirect URLs, and grant required API scopes such as openid, profile, email, and groups. The Client ID and Client Secret are then used to configure Zscaler authentication.

SCIM provisioning can also be enabled to synchronize users and groups automatically between Okta and Zscaler.

On-Premises AD Integration (ZAB)

For organizations relying on **Active Directory**, integration is achieved through the **Zscaler Authentication Bridge (ZAB)**.

The ZAB connector runs on Windows servers within the internal network and communicates with Zscaler cloud services using outbound HTTPS connections. This design avoids the need for inbound firewall rules. The connector performs LDAP queries against domain controllers and synchronizes user and group information with Zscaler. Multiple connectors should be deployed for high availability and load balancing.

Directory Connector Configuration

After deploying ZAB, administrators configure directory connectors within the Zscaler portal. LDAP settings, search base DNs, and synchronization filters are defined to ensure only relevant users and groups are imported. Attribute mapping links directory attributes to Zscaler user fields, while synchronization schedules control how frequently updates occur. Logging and monitoring features help verify successful synchronization and detect errors during deployment.

Conclusion

In conclusion, this project explored the role of AI and modern security technologies in strengthening web security.

Stage 1 focused on web application testing and highlighted the importance of identifying vulnerabilities to protect web-based systems. Understanding these security weaknesses provided the foundation for implementing effective protection strategies.

Stage 2 analyzed vulnerability assessment reports generated by **Nessus**, demonstrating how detailed scanning and reporting help organizations detect risks and take corrective actions to improve their cybersecurity posture.

Stage 3 implemented a Zero Trust security approach using **IBM QRadar** and **Zscaler Private Access**, replacing traditional VPN-based access with identity-based authentication and secure application connectivity. This approach reduces attack surfaces, prevents lateral movement, and improves user experience through secure and efficient access controls.

Overall, the project demonstrates how combining AI-driven analysis, vulnerability assessment tools, and Zero Trust architecture can significantly enhance modern cybersecurity frameworks. These technologies provide a strong foundation for future security improvements, enabling organizations to detect threats faster, automate security processes, and maintain a resilient security posture.

Future Scope

Future of Web Application Testing

The future of web application testing will focus heavily on security, automation, and intelligent analysis as applications grow more complex. Increased cyber threats will require stronger vulnerability detection and continuous monitoring. The use of **AI and machine learning** will expand to automate test generation, detect anomalies, and improve the accuracy of security testing. In addition, many organizations will adopt **cloudbased testing platforms** for better scalability, flexibility, and cost efficiency. Greater emphasis will also be placed on **user experience testing** to ensure secure and user-friendly applications.

Future Scope of the Testing Process

Software testing will increasingly adopt **continuous testing throughout the software development lifecycle (SDLC)** to detect defects early and improve reliability. Automation tools will play a major role in executing test cases faster and reducing manual effort. AI-driven testing tools will help identify complex vulnerabilities and optimize testing strategies. Cloud-based testing environments will further support scalable and cost-effective testing infrastructure.

Future Scope of SOC / SIEM

Future improvements in Security Operations Centers will focus on deeper integration between identity, network security, and threat intelligence platforms. Expanding integrations with identity systems such as **Ping Identity**, **OneLogin**, and **Google Workspace** can support diverse user environments. Enhanced device posture checks using endpoint protection tools like **CrowdStrike**, **SentinelOne**, and **Microsoft Defender for Endpoint** will enable stronger access control.

Future deployments may also integrate **security orchestration and automation (SOAR)** systems to automate incident response and threat remediation. Advanced analytics and user behavior monitoring will further improve threat detection and help organizations implement adaptive, identity-based security models aligned with Zero Trust principles.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis,
Sharing and Distribution, Integration with Security Tools, Customization and Flexibility,
Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END